



UNIVERSIDAD ESTATAL AMAZÓNICA

SEMANA:

10

TAREA:

Evaluación de amenazas y nivel de riesgo en sistemas informáticos

MATERIA:

Administración de sistemas operativos

PARALELO:

D

ESTUDIANTE:

MINAYA GARCIA JEFFERSON CRISTOPHER

PERIODO

2026 – 2026

1. CONTEXTO DEL SISTEMA SELECCIONADO

Se selecciona como caso simulado la infraestructura de red de un laboratorio académico universitario. El entorno está compuesto por 25 estaciones de trabajo con Windows 11, un servidor de archivos y autenticación, una base de datos con información de estudiantes, un punto de acceso inalámbrico y un firewall de borde. Los usuarios son docentes, estudiantes y personal de soporte; por ello, existe diversidad de privilegios, dispositivos y hábitos de navegación.

El objetivo es identificar tres amenazas que no sean ransomware, estimar su impacto sobre la confidencialidad, integridad y disponibilidad (CID), valorar la probabilidad mediante los niveles de amenaza y vulnerabilidad, y priorizar controles de tratamiento. La valoración es cualitativa-cuantitativa y se aplica de manera consistente a los tres escenarios.

2. METODOLOGÍA Y ESCALA DE VALORACIÓN

Se utiliza la relación indicada en la guía de la actividad: $\text{Riesgo} = \text{Impacto (CID)} \times \text{Nivel de amenaza} \times \text{Nivel de vulnerabilidad}$. Cada factor se valora de 1 a 3, donde 1 representa una condición baja, 2 una condición media y 3 una condición alta. Para interpretar el resultado se emplean los rangos: 1–9 bajo, 10–18 medio y 19–27 alto. El criterio es coherente con el principio de que el riesgo aumenta cuando una amenaza tiene mayor posibilidad de materializarse sobre una vulnerabilidad y producir consecuencias relevantes [1].

Factor	1 – Bajo	2 – Medio	3 – Alto
Impacto CID	Afectación menor y recuperable	Interrupción o exposición parcial	Afectación crítica al servicio o datos
Nivel de amenaza	Poco probable / ocasional	Probable en el contexto	Muy probable o frecuente
Nivel de vulnerabilidad	Controles sólidos	Controles parciales	Debilidad evidente o ausencia de control

3. MATRIZ DE EVALUACIÓN DE RIESGOS

La siguiente matriz resume los activos, amenazas, vulnerabilidades, controles existentes, cálculo y tratamiento propuesto. Los tres casos se han elegido para representar riesgos de ingeniería social, disponibilidad de red y abuso de privilegios, evitando repetir la amenaza de ransomware del ejemplo.

N° activo	Nombre del activo	Amenaza	Vulnerabilidad	Impacto CID	Nivel de amenaza	Nivel de vulnerabilidad	Controles existentes	Cálculo del riesgo	Nivel de riesgo	Medidas de mitigación
A1	Cuentas y servidor de archivos	Phishing y robo de credenciales	Usuarios sin MFA y capacitación irregular; enlaces maliciosos pueden capturar contraseñas.	3	3	3	Filtro antispam básico; antivirus; contraseñas institucionales.	$3 \times 3 \times 3 = 27$	ALTO	Activar MFA para correo, VPN y cuentas administrativas. Configurar SPF, DKIM y DMARC. Capacitar con simulaciones de phishing. Aplicar mínimo privilegio y revisar accesos.
A2	Firewall, router y enlace a Internet	Ataque de denegación de servicio (DDoS)	Servicios publicados sin protección anti-DDoS y reglas de rate limiting insuficientes.	3	2	3	Firewall perimetral; monitoreo básico; respaldo del enlace no automatizado.	$3 \times 2 \times 3 = 18$	MEDIO	Contratar protección anti-DDoS del proveedor. Limitar tasas y cerrar puertos innecesarios. Implementar redundancia de Internet. Definir procedimiento de escalamiento y continuidad.
A3	Base de datos académica	Acceso no autorizado por abuso de privilegios	Permisos excesivos en cuentas de soporte y revisiones de roles poco frecuentes.	3	2	3	Autenticación por usuario; registros de acceso; copias de seguridad semanales.	$3 \times 2 \times 3 = 18$	MEDIO	Aplicar RBAC y mínimo privilegio. Separar cuentas administrativas y de uso diario. Revisar permisos trimestralmente. Centralizar logs y activar alertas de consultas anómalas.

4. JUSTIFICACIÓN DE LOS VALORES Y EFECTO EN EL ENTORNO

Amenaza 1: phishing y robo de credenciales

El impacto se valora en 3 porque una cuenta comprometida permitiría acceder al servidor de archivos, consultar información académica o modificar documentos compartidos, afectando la confidencialidad e integridad. El nivel de amenaza es 3 debido a que el correo institucional y los servicios de nube son objetivos frecuentes de campañas de ingeniería social. La vulnerabilidad es 3 porque no todos los usuarios emplean autenticación multifactor y la capacitación es irregular. Por ello, el resultado 27 se clasifica como alto y requiere tratamiento prioritario.

Amenaza 2: ataque DDoS

El impacto se asigna en 3 porque la saturación del enlace o del firewall puede dejar sin conectividad al laboratorio, interrumpir clases virtuales y bloquear servicios publicados. La amenaza se valora en 2, ya que el ataque es técnicamente posible, aunque no necesariamente constante en una institución pequeña. La vulnerabilidad es 3 debido a que el entorno no cuenta con protección anti-DDoS dedicada ni redundancia automática. El riesgo 18 es medio, pero puede elevarse si se publican nuevos servicios o aumenta la dependencia de Internet.

Amenaza 3: abuso de privilegios

El impacto es 3 porque una cuenta interna con permisos excesivos podría extraer, alterar o eliminar registros de estudiantes, afectando confidencialidad, integridad y continuidad operativa. El nivel de amenaza es 2: el abuso puede ser intencional o accidental y requiere acceso válido, pero no es inevitable. La vulnerabilidad es 3 porque los roles no se revisan con frecuencia y las cuentas administrativas no están suficientemente separadas. El resultado 18 es medio y debe reducirse mediante control de accesos, trazabilidad y revisiones periódicas.

5. CONCLUSIONES

La evaluación muestra que el riesgo más urgente es el phishing con robo de credenciales, debido a la combinación de impacto crítico, alta exposición y controles incompletos. Los riesgos DDoS y abuso de privilegios alcanzan un nivel medio, pero pueden interrumpir servicios esenciales o comprometer datos sensibles si no se gestionan de forma preventiva.

Las medidas propuestas combinan controles técnicos, administrativos y de continuidad. La prioridad de implementación debe ser la autenticación multifactor y la formación contra ingeniería social; después, la protección de disponibilidad de red y, de manera continua, la revisión de privilegios y el monitoreo de registros. La valoración debe actualizarse cuando cambien los activos, los servicios publicados o los perfiles de usuario.

Referencias

- [1] National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments*, NIST SP 800-30 Rev. 1. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- [2] Material complementario de la asignatura. *Guía para la Gestión de Riesgos de Seguridad de la Información*, páginas 12, 15–18. Documento proporcionado para la actividad.